

SOLARWINDS SUPPLY CHAIN ATTACK (2020)

Nation-State Attack · Supply Chain · 18,000 Victims · 9 Months Undetected

THIS PROJECT: Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

CVE / ADVISORY: CVE-2020-10148 (SolarWinds Orion API Authentication Bypass, CVSS 9.8 CRITICAL) — nvd.nist.gov

INCIDENT OVERVIEW

In late 2020, security firm FireEye discovered that nation-state attackers — later attributed to Russia's SVR intelligence service (APT29/Cozy Bear) — had injected malicious code (SUNBURST) into SolarWinds' Orion IT monitoring software update. Approximately 18,000 organizations installed the trojanized update. Victims included U.S. Departments of Treasury, State, Homeland Security, Defense, and Justice, plus Microsoft and thousands of private organizations. Attackers remained undetected for 9+ months, moving silently through government networks. This is widely considered the most sophisticated cyberattack in history.

KEY FACTS AT A GLANCE

- ~18,000 organizations downloaded the trojanized Orion software update
- ~100 organizations were actively exploited for deeper access (including U.S. government agencies)
- Attacker: APT29 / Cozy Bear — Russia's SVR foreign intelligence service
- SUNBURST backdoor stayed dormant for 12–14 days after installation before activating
- Used DNS-based C2 — traffic blended perfectly with legitimate Orion network monitoring
- Attackers remained undetected for approximately 9 months
- Microsoft President Brad Smith called it "the most sophisticated and largest cyberattack in history"

PROJECT 5 · DAY 1

MONDAY — INCIDENT INTRODUCTION + CIA TRIAD

1–2 HRS

OBJECTIVE: Students understand the SolarWinds Supply Chain Attack at a high level and apply the CIA Triad to identify which pillars were violated and how.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:15	Welcome & Project Overview	Distribute Project 5 packet. Explain: this project is about understanding exactly what happened. Next project we apply frameworks and write the executive summary.
0:15-0:45	Lecture: CIA Triad	Teach Confidentiality, Integrity, Availability. Use real-world examples. Ask: what happens when each one fails?
0:45-1:10	Read the Incident	Students read the Incident Overview (15 min silent). Then open discussion: What happened? What was your first reaction?
1:10-1:50	CIA Triad Mapping Activity	Students fill out their CIA Triad worksheet — which pillars were violated, specific evidence, impact rating (Low/Med/High/Critical).
1:50-2:00	Debrief & Homework	Share out. Homework: Write a 1-paragraph plain-English explanation of the incident for a non-technical reader.

PROJECT 5 • DAY 2

TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES

1-2 HRS

OBJECTIVE: Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: Kill Chain	Teach the 7 phases. For each: what does the attacker do? At what point could a defender have stopped this?
0:30-1:00	Demo: Phase Walkthrough	Walk through ONE Kill Chain phase together as a class. Model your analysis process out loud.
1:00-1:45	Kill Chain Mapping	Students complete the full Kill Chain table — all 7 phases with specific incident evidence, not generic descriptions.
1:45-2:00	Discussion	Which phase was the most preventable? Which phase was most surprising? What would have stopped the attack?

PROJECT 5 • DAY 3

WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB

1-2 HRS

OBJECTIVE: Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: MITRE ATT&CK	Explain Tactics (the WHY), Techniques (the HOW), Procedures (the specific implementation). Show the ATT&CK Navigator.
0:30-0:50	Live Demo: attack.mitre.org	Navigate the matrix together. Look up ONE technique from this incident. Show the description, procedure examples, and detection methods.
0:50-1:40	ATT&CK Research Lab	Students identify 3-5 techniques from the incident. For each: ID, name, tactic, and plain-English explanation.
1:40-2:00	Class ATT&CK Heat Map	Build a shared map on the board. Students add techniques. What does the pattern tell us about where to focus defenses?

PROJECT 5 • DAY 4	THURSDAY — CVE RESEARCH LAB + WORKSHEET SUBMISSION (50 PTS)	1-2 HRS
--------------------------	--	----------------

OBJECTIVE: Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	CVE Orientation	Walk students through nvd.nist.gov and cisa.gov . Show them how to read a CVE entry: description, CVSS score, references.
0:20-1:10	Research Lab + Worksheet	Students research: CVE-2020-10148 (CVSS 9.8), CISA Emergency Directive 21-01, FireEye SUNBURST Report. Document: patch/fix, when available, how the incident was contained, who was involved.
1:10-1:40	Timeline + Finalization	Students build the incident timeline. Finalize the CVE Research Worksheet. Instructor circulates to answer last-minute questions.
1:40-2:00	Submit + Next Project Preview	Students submit completed CVE Research Worksheet (50 points). Open discussion: What surprised you? Preview next project: NIST CSF, attacker methodology, and Executive Summary.

KILL CHAIN REFERENCE — FULL ANALYSIS

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
1. Reconnaissance	APT29 studied SolarWinds' software build process; identified Orion updates as a mass distribution mechanism	Threat intelligence; dark web monitoring; monitor vendor relationships

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
2. Weaponization	Developed SUNBURST backdoor; injected it into SolarWinds' Orion source code during the build process	Patch management; secure development practices; code signing
3. Delivery	SolarWinds unknowingly delivered the malware via its own legitimate signed software update to 18,000 customers	Email filtering; MFA; user security awareness training
4. Exploitation	SUNBURST laid dormant 12-14 days then checked for security tools and sandbox environments before activating	Patch known CVEs; WAF; regular penetration testing
5. Installation	Established SUNBURST backdoor; deployed TEARDROP + Cobalt Strike at high-value targets	File integrity monitoring; application whitelisting; EDR
6. Command & Control	Used DNS queries to avsvmcloud[.]com subdomains — mimicked legitimate Orion telemetry traffic	DNS filtering; SSL inspection; anomaly detection on outbound traffic
7. Actions on Obj.	Stole auth tokens, moved to cloud environments (M365, Azure AD), accessed emails and documents for 9+ months	Data loss prevention (DLP); database activity monitoring; network segmentation

MITRE ATT&CK TECHNIQUE REFERENCE

TECHNIQUE ID	TECHNIQUE NAME	HOW IT WAS USED
T1195.002	Compromise Software Supply Chain	Injected SUNBURST backdoor into SolarWinds' legitimate Orion build pipeline
T1071.004	DNS Command and Control	Used DNS queries for C2 — blended with legitimate network monitoring traffic
T1027	Obfuscated Files and Information	SUNBURST carefully mimicked legitimate SolarWinds code to evade detection
T1550.001	Application Access Token	Forged SAML tokens to access Microsoft 365 and Azure cloud environments
T1562	Impair Defenses	SUNBURST checked for security tools before activating — disabled if found

CVE / ADVISORY REFERENCE

IDENTIFIER: CVE-2020-10148 (SolarWinds Orion API Authentication Bypass, CVSS 9.8 CRITICAL) — nvd.nist.gov

HOW IT WAS PATCHED

- CVE-2020-10148: SolarWinds released Orion hotfix 2020.2.1 HF1 (Dec 15, 2020) then HF2 (Dec 23, 2020)
- CISA Emergency Directive 21-01: All federal agencies ordered to immediately power off or disconnect ALL Orion instances
- Microsoft, GoDaddy, and FireEye collaborated to sinkhole the SUNBURST C2 domain avsvmcloud[.]com
- High-value targets directed to completely rebuild affected systems from scratch rather than just patch
- All credentials, tokens, and certificates on systems touching Orion had to be rotated or revoked

HOW THE INCIDENT WAS CONTAINED

- FireEye discovered breach while investigating their own network; notified NSA, CISA, FBI immediately
- Sinkholing avsvmcloud[.]com allowed researchers to identify all infected organizations (who "phoned home")
- CISA stood up 24/7 incident coordination center for the SolarWinds response
- Cyber Unified Coordination Group (NSA, CISA, FBI, ODNI) coordinated the full government response

INCIDENT TIMELINE

DATE	EVENT
Oct 2019	Attackers first access SolarWinds build environment
Mar 26, 2020	Malicious Orion update officially released to 18,000 customers
Mar–Oct 2020	Attackers silently access government networks — 9+ months undetected
Dec 8, 2020	FireEye publicly discloses their own breach
Dec 13, 2020	SolarWinds supply chain attack publicly disclosed; CISA issues ED 21-01
Dec 14, 2020	C2 domain avsvmcloud[.]com sinkholed by Microsoft/GoDaddy/FireEye
Dec 15–23	SolarWinds releases HF1 and HF2 patches
May 2021	Executive Order 14028 — SBOM and Zero Trust now required for federal contractors

PROJECT 5 ASSESSMENT — CVE RESEARCH WORKSHEET (50 POINTS)

DUE: Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- FireEye Blog: "Highly Evasive Attacker Leverages SolarWinds Supply Chain" (December 13, 2020) — [mandiant.com](https://www.mandiant.com)
- CISA Emergency Directive 21-01 — [cisa.gov/emergency-directive-21-01](https://www.cisa.gov/emergency-directive-21-01)
- nvd.nist.gov/vuln/detail/CVE-2020-10148 — full technical details
- U.S. Senate Intelligence Committee: SolarWinds Hearing (February 23, 2021)
- Executive Order 14028 on Improving the Nation's Cybersecurity — [whitehouse.gov](https://www.whitehouse.gov)
- MITRE ATT&CK: attack.mitre.org — search T1195, T1071, T1027